

EncryptEdge Labs

Junior Cloud Security Engineer Internship Programme

Junior Cloud Security Engineer

Internship Task Report

Intern Full Name	[REDACTED]
Intern Email	[REDACTED]
Cohort	Cohort 7 2026
Task ID	CSE-AWS-L-025-03
Task Title	IAM Initial Access via Weak Credentials and Enumeration Techniques
Skill Domain	AWS Identity and Access Management (IAM) Security
Difficulty Level	Intermediate
CPE Credits	3 CPE Credits
Guiding Framework(s)	MITRE ATT&CK; AWS IAM security best practices; least privilege
Submission Date	31 August 2026

All activities described in this report are limited to authorised lab environments. Evidence not supplied or not yet verified is clearly marked as pending rather than represented as completed.

1.0 Task Overview

Task ID	CSE-AWS-L-025-03
Task Title	IAM Initial Access via Weak Credentials and Enumeration Techniques
Skill Domain	AWS Identity and Access Management (IAM) Security
Difficulty	Intermediate
Duration	11 Hours
CPE Credits	3 CPE Credits
Cloud Platform(s)	Dedicated AWS lab account; iam-vulnerable training environment; hosted Cybr and PwnedLabs labs
AWS Region(s) Used	Not confirmed in supplied evidence
Primary Tools	AWS CLI, iam-vulnerable, Terraform, ScoutSuite, Cloudsplaining, ChatGPT, jq, Python 3
Target Environment	iam-vulnerable tool-testing modules simulating weak credentials and IAM enumeration scenarios
MITRE ATT&CK IDs	T1078 Valid Accounts; T1087.004 Account Discovery: Cloud Account; T1069.003 Permission Groups Discovery: Cloud Groups
Guiding Frameworks	MITRE ATT&CK; least-privilege IAM principles
Regulatory Alignment	ISO/IEC 27001 access control and identity management principles; NIST access-control concepts

1.1 Introduction

This task examines how weak or exposed credentials and excessive IAM permissions can provide an attacker with initial access to an AWS environment. The lab combines IAM enumeration, permission review, automated assessment, and risk analysis so that a cloud security engineer can connect identity weaknesses to realistic privilege-escalation paths and business impact.

1.2 Objectives & Learning Outcomes

- Understand cloud initial-access techniques involving valid accounts, leaked credentials, weak passwords, and over-permissive IAM policies - completed through MITRE ATT&CK review and AI-assisted conceptual analysis.
- Deploy an authorised IAM-vulnerable AWS homelab - AWS CLI connectivity and the presence of multiple iam-vulnerable users were verified in the lab account.
- Enumerate IAM identities and permissions - IAM users were successfully listed and the environment exposed multiple deliberately named privilege-escalation test identities.
- Assess IAM policy misconfiguration and privilege-escalation risk - a Phase D risk matrix was produced, with Cloudsplaining verification to be attached when the scan output is available.
- Reinforce the work through hosted IAM enumeration labs and professional reporting - hosted-lab proof remains pending unless separately supplied; this report consolidates the completed and observed work.

1.3 Scope & Legal Authorisation

All testing was scoped to authorised training resources: the dedicated AWS lab account used for iam-vulnerable, the local WSL workstation used to run AWS CLI and supporting tools, and the Cybr/PwnedLabs hosted training environments specified by the task. No production systems, third-party AWS accounts, customer resources, or real customer data were intentionally accessed. ChatGPT was used for explanation, troubleshooting guidance, summarisation, and report drafting; it was not treated as a source of technical execution evidence.

1.4 MITRE ATT&CK Cloud Threat Mapping

Technique ID	Technique Name	Relevance to This Task
T1078	Valid Accounts	Weak, leaked, or reused credentials can allow an attacker to authenticate as a legitimate cloud identity.
T1087.004	Account Discovery: Cloud Account	IAM user enumeration reveals available cloud identities and potential targets for follow-on activity.

T1069.003	Permission Groups Discovery: Cloud Groups	Reviewing group and policy relationships helps identify identities that may inherit elevated permissions.
-----------	---	---



2.0 Environment & Tool Setup

2.1 Cloud Architecture Overview

The lab used a Windows workstation with WSL as the local execution environment and a dedicated AWS lab account as the cloud target. The iam-vulnerable project provided intentionally insecure IAM scenarios. AWS CLI was used to verify identity and enumerate IAM resources, while ScoutSuite and Cloudsplaining were intended to provide automated security analysis.

Cloud Resource / Component	Type / Service	Role in Task	Region / Config Notes
Dedicated AWS lab account	AWS account	Authorised target for IAM-vulnerable deployment and enumeration	Account ID redacted in report; region not confirmed
iam-vulnerable	Terraform/IAM lab	Creates intentionally vulnerable IAM identities and privilege-escalation scenarios	Deployed against real AWS rather than LocalStack
WSL workstation	Local Linux environment	Runs AWS CLI, Terraform, jq, ScoutSuite and Cloudsplaining	Windows host / WSL
IAM users and policies	AWS IAM	Objects enumerated and analysed for weak access and escalation risk	Global AWS IAM service
Cybr / PwnedLabs	Hosted training labs	Guided IAM enumeration practice	External authorised training platforms

2.2 AWS CLI & Tool Configuration

Tool / Service	Version	Installation / Configuration	Purpose
AWS CLI	Installed; exact version not captured	Configured default profile in WSL	Identity verification and IAM enumeration
Terraform	Installed for Phase B	Used with iam-vulnerable repository	Provisioning the lab
jq	Initially missing	Ubuntu package installation recommended	JSON output filtering
ScoutSuite	Installation attempted via pip; PEP 668 blocked system install	pipx recommended for isolated installation	AWS security posture / IAM assessment
Cloudsplaining	Planned via pipx	Separate Python CLI environment recommended	IAM authorization analysis and privilege-escalation findings
ChatGPT	AI assistant	Interactive use	Concept summary, troubleshooting, risk language, reporting

Verified configuration result: AWS STS returned a valid IAM caller identity for the lab account, and IAM enumeration returned the iam-vulnerable test users. The full account number is intentionally omitted from this report.

2.3 AI Tool Usage Declaration

AI Tool	Used For	What Was NOT Done with AI
ChatGPT	MITRE/IAM concept summary; least-privilege explanation; troubleshooting LocalStack vs real AWS; report drafting and risk-matrix wording	AI was not used as proof that Terraform, ScoutSuite, Cloudsplaining, or hosted labs completed. Unverified evidence is marked pending.

3.0 Methodology - Phase Execution

Phase A: Theory & Introduction

Phase Objective	Understand how attackers exploit weak credentials and misconfigured IAM policies.
Estimated Time	60 minutes
Evidence File(s)	phaseA_summary.png

Actions Taken

MITRE ATT&CK cloud initial-access concepts were reviewed with emphasis on Valid Accounts and credential exposure. The analysis considered leaked access keys, guessable or reused passwords, absence of MFA, long-lived credentials, and policies with wildcard actions or resources. An AI-assisted summary was prepared explaining how least privilege reduces the blast radius of a compromised identity.

Key Observations

Credential compromise becomes substantially more damaging when the affected principal has broad IAM permissions. Least privilege limits the actions and resources available to a compromised identity, while MFA, short-lived credentials, credential rotation, and regular policy review reduce the likelihood and duration of misuse.

Evidence Produced

- phaseA_summary.png - AI-generated conceptual summary covering initial access, weak credentials, excessive IAM permissions, and least privilege.

Phase B: Setup Homelab Environment

Phase Objective	Deploy the iam-vulnerable environment using Terraform in a dedicated AWS lab account.
Estimated Time	90 minutes
Evidence File(s)	phaseB_setup.png - pending attachment/verification

Actions Taken

The iam-vulnerable repository was used as the target lab. AWS CLI connectivity was verified from WSL. Subsequent IAM enumeration showed numerous iam-vulnerable users, which supports that the lab resources were present in the AWS account. The supplied Phase C instructions referenced localhost:4566, but troubleshooting established that Docker/LocalStack was not installed and the active target was the real authorised AWS lab account.

Key Observations

The active AWS CLI session authenticated successfully to the dedicated lab account. Because the environment was AWS-hosted rather than LocalStack-hosted, commands containing the LocalStack endpoint failed and had to be adjusted to use normal AWS endpoints.

Evidence Produced

- phaseB_setup.png - required screenshot of successful Terraform deployment and AWS CLI identity verification; not supplied with this report generation request, so status is Pending.

Phase C: Core Execution - Enumeration & Weak Credential Testing

Phase Objective	Enumerate IAM entities and identify weak credentials within the sandbox.
Estimated Time	150 minutes
Evidence File(s)	phaseC_enum.png; phaseC_report.png

Actions Taken

IAM users were enumerated through AWS CLI. The command returned many deliberately vulnerable identities, including users associated with policy-version changes, inline-policy modification, role-policy modification, group membership

changes, assume-role policy updates, PassRole/Lambda paths, SSM, SageMaker, CodeBuild, and other scenarios. The initial jq-based command could not run because jq was missing, and the LocalStack endpoint failed because no service was listening on port 4566. The enumeration was therefore repeated against AWS directly using AWS CLI query/output formatting.

ScoutSuite installation was attempted. The operating system returned an externally-managed-environment (PEP 668) error for system-wide pip installation, so pipx was selected as the safer isolated installation method. A completed ScoutSuite report was not supplied in the available evidence, so no ScoutSuite-specific finding is represented as confirmed.

Key Observations

The IAM user list clearly demonstrated that the training account contained multiple identities designed around privilege-escalation techniques. The troubleshooting also highlighted an operational lesson: tool instructions must match the deployed environment, because LocalStack-specific endpoints are not valid for an AWS-hosted deployment.

Evidence Produced

- phaseC_enum.png - required enumeration screenshot; the command output was observed in-session but the image file was not supplied.
- phaseC_report.png - ScoutSuite report summary; pending until the actual scan is completed and captured.

Phase D: Independent Extension - Policy Misconfiguration Analysis

Phase Objective	Analyze discovered policies for privilege escalation potential.
Estimated Time	120 minutes
Evidence File(s)	phaseD_risk_matrix.xlsx; phaseD_matrix.png

Actions Taken

The IAM-vulnerable identity names observed during enumeration were mapped to likely privilege-escalation categories and prioritised in a risk matrix. Cloudsplaining was identified as the intended authorization-analysis tool. Because a simple list-policies export contains policy metadata rather than complete authorization details, the recommended workflow was to use Cloudsplaining's authorization-details download/scan process. No Cloudsplaining HTML output was supplied, so the matrix is treated as an analytical risk assessment rather than a claim that Cloudsplaining confirmed every row.

Key Observations

The highest-risk patterns are IAM write permissions that can alter effective authorization: creating or selecting policy versions, writing inline policies, changing role policies or trust policies, adding users to privileged groups, and passing privileged roles to compute services. These permissions can transform an initially limited identity into a highly privileged principal if not constrained.

Evidence Produced

- phaseD_risk_matrix.xlsx - completed analytical risk matrix.
- phaseD_matrix.png - required combined screenshot of Cloudsplaining output and matrix.

Risk Matrix (Phase D Output)

Cloud Asset / Resource	Threat / Risk	MITRE Ref.	Likelihood	Impact	Score	Rating
IAM managed policy	Create/set a new policy version to gain broader permissions	T1078	5	5	25	Critical
IAM user	Write an inline user policy granting elevated access	T1078	5	5	25	Critical
IAM role	Modify inline role policy to expand privileges	T1078	5	5	25	Critical
IAM group	Add a user to a	T1069.003	4	5	20	Critical

	privileged group					
IAM role trust policy	Change AssumeRole trust relationship	T1078	5	5	25	Critical
IAM PassRole / Lambda	Pass a privileged role to a new workload and invoke it	T1078	5	5	25	Critical

Phase E: Hosted Labs Integration

Phase Objective	Reinforce learning through guided hosted labs.
Estimated Time	180 minutes
Evidence File(s)	phaseE_labproof.png - pending

Actions Taken

The task requires completion of Cybr's Introduction to AWS IAM Enumeration lab followed by PwnedLabs' Intro to AWS IAM Enumeration lab. No completion certificate, progress dashboard, or screenshot was supplied with the current report request; therefore this phase is documented as required but not represented as completed.

Key Observations

The hosted labs are intended to reinforce account discovery, IAM enumeration, and permission-analysis techniques in controlled environments. Final observations should be updated after the completion proof is captured.

Evidence Produced

- phaseE_labproof.png - Pending.

Phase F: Documentation & Reporting

Phase Objective	Compile findings into a professional security report.
Estimated Time	Reporting phase
Evidence File(s)	CSE_AWS_IAM_Report_██████████_Kaur.pdf

Actions Taken

The available phase objectives, observed AWS CLI results, troubleshooting notes, IAM enumeration findings, risk matrix, MITRE mappings, defensive recommendations, and evidence status were consolidated into the EncryptEdge Labs reporting structure. Sensitive account identifiers were excluded from the report body, and unverified evidence was explicitly marked pending.

Key Observations

The exercise demonstrates that identity security depends on both credential strength and authorization scope. Enumeration provides the visibility needed to identify attack paths, while policy analysis and least-privilege remediation reduce the chance that one compromised identity can become an account-wide incident.

Evidence Produced

- CSE_AWS_IAM_Report_██████████_Kaur.pdf - final PDF report.

4.0 Findings

4.1 Findings Summary

#	Finding Title	Type / Category	Cloud Service / Resource	MITRE Ref.	Phase	Severity	Evidence Ref.
1	Multiple privilege-escalation test identities exposed by IAM enumeration	Privilege Escalation Path	AWS IAM users	T1087.004	C	High	phaseC_enum.png / observed CLI output
2	IAM policy-write paths can expand effective permissions	IAM Policy Gap	IAM policies/users/roles	T1078	D	Critical	phaseD_risk_matrix.xlsx
3	PassRole and workload-based escalation paths present in lab scenarios	Privilege Escalation Path	IAM + Lambda/other services	T1078	D	Critical	phaseD_risk_matrix.xlsx
4	Environment/tooling mismatch caused LocalStack endpoint failure	Configuration / Operational Gap	AWS CLI / local tooling	N/A	C	Low	Troubleshooting notes

4.2 Detailed Finding Analysis

Finding 1: IAM Enumeration Revealed Multiple Escalation-Oriented Identities

Finding Title	Finding 1: IAM Enumeration Revealed Multiple Escalation-Oriented Identities
Type / Category	Privilege Escalation Path / Account Discovery
Cloud Service / Resource	AWS IAM users
Description	IAM enumeration returned numerous deliberately named iam-vulnerable users associated with policy manipulation, PassRole, AssumeRole, Lambda, SSM, SageMaker, CodeBuild and related escalation scenarios.
How Identified	AWS CLI IAM user enumeration against the authorised AWS lab account.
MITRE ATT&CK Reference	T1087.004 - Account Discovery: Cloud Account
Business / Security Impact	In a real environment, broad visibility of identities can help an attacker identify high-value principals and focus credential or privilege-escalation attempts. The risk becomes significant when discovered identities also possess IAM write permissions.
Severity / Impact	High
Evidence Reference	phaseC_enum.png / observed CLI output

Finding 2: IAM Policy Modification Can Enable Privilege Escalation

Finding Title	Finding 2: IAM Policy Modification Can Enable Privilege Escalation
Type / Category	IAM Policy Gap / Privilege Escalation Path
Cloud Service / Resource	AWS IAM policies, users and roles
Description	The lab includes identities whose scenario names correspond to creating policy versions, writing inline user policies, writing role policies and changing assume-role policies. These are high-risk authorization changes because they can alter the permissions available to a principal.
How Identified	IAM enumeration followed by Phase D risk analysis. Cloudspaining confirmation remains pending.
MITRE ATT&CK Reference	T1078 - Valid Accounts
Business / Security Impact	If a compromised principal can modify authorization policy, an attacker may convert valid but limited access into administrative or otherwise sensitive access, threatening

	confidentiality and integrity across the account.
Severity / Impact	Critical
Evidence Reference	phaseD_risk_matrix.xlsx

Finding 3: PassRole and Workload Creation Create High-Impact Escalation Paths

Finding Title	Finding 3: PassRole and Workload Creation Create High-Impact Escalation Paths
Type / Category	Privilege Escalation Path
Cloud Service / Resource	AWS IAM with Lambda / service roles
Description	The enumerated lab identities include PassRole-related scenarios in which a user may be able to associate a more privileged role with a service workload and then cause that workload to execute.
How Identified	IAM enumeration and Phase D analytical risk mapping.
MITRE ATT&CK Reference	T1078 - Valid Accounts
Business / Security Impact	Improperly constrained iam:PassRole can allow a lower-privileged identity to indirectly exercise permissions held by a more privileged role, potentially leading to data access, resource modification, persistence, or account compromise.
Severity / Impact	Critical
Evidence Reference	phaseD_risk_matrix.xlsx

5.0 Risk Assessment & Cloud Threat Model

5.1 Cloud Security Control Gaps & Defensive Coverage

Finding / Gap	Observable / Trigger in Cloud Telemetry	Recommended Control	AWS Service / Tool
IAM policy modification	CreatePolicyVersion, SetDefaultPolicyVersion, PutUserPolicy, PutRolePolicy events	Restrict IAM write permissions; alert on high-risk IAM changes; require approved admin roles	CloudTrail, CloudWatch, IAM Access Analyzer, SCPs
Trust-policy / AssumeRole changes	UpdateAssumeRolePolicy and unusual AssumeRole activity	Tight trust conditions; restrict trust-policy edits; monitor role assumption	CloudTrail, IAM Access Analyzer, AWS Organizations SCP
PassRole escalation	PassRole combined with workload creation or update	Restrict iam:PassRole by exact role ARN and aws:PassedToService; separate deployment and IAM administration duties	IAM policies, SCPs, CloudTrail
Weak / exposed credentials	ConsoleLogin failures/successes, API calls from unusual context	MFA, short-lived role credentials, access-key rotation, credential monitoring	IAM, CloudTrail, GuardDuty

5.2 Risk Exposure Over Time

Risk 1 - IAM policy modification: If high-risk IAM write permissions remain available to ordinary or compromised principals, the environment retains a direct path from limited access to broader authorization. Over time, this increases the chance that a single credential compromise becomes an account-wide confidentiality and integrity incident.

Risk 2 - PassRole/workload escalation: Unrestricted role passing can persist unnoticed because the attacker may operate through a service role rather than the original user. This can complicate attribution and allow access to resources that the original identity could not directly reach.

Risk 3 - Weak credentials and valid accounts: Long-lived or weak credentials provide a reusable entry point. Without MFA, rotation, anomaly detection, and least privilege, the exposure window remains open and repeated access may blend with legitimate activity.

6.0 Recommendations

6.1 Technical Remediation

#	Finding	Specific Remediation Action	Priority	Standard / Reference
1	IAM policy modification	Remove unnecessary iam:CreatePolicyVersion, iam:SetDefaultPolicyVersion, iam:PutUserPolicy and iam:PutRolePolicy permissions from non-administrative identities; scope remaining permissions to approved resources.	Immediate	Least privilege; ISO/IEC 27001 access control principles
2	Trust-policy modification	Restrict iam:UpdateAssumeRolePolicy; require explicit trusted principals and conditions in role trust policies; review changes through controlled administration.	Immediate	MITRE T1078 mitigation through stronger identity/access governance
3	PassRole escalation	Allow iam:PassRole only for specific role ARNs and approved AWS services; separate workload deployment permissions from IAM	Immediate	AWS IAM least privilege

		administration.		
4	Weak credentials	Require MFA for interactive users, prefer role-based temporary credentials, remove unused access keys, and rotate exposed or unnecessary long-lived credentials.	Short-term	Credential lifecycle and least-privilege controls
5	Detection coverage	Create CloudTrail/CloudWatch detections for high-risk IAM write actions and investigate unexpected changes promptly.	Short-term	Continuous monitoring / identity change detection

6.2 Strategic & Operational Improvements

- Adopt a least-privilege review cycle for IAM users, groups, roles, and policies, with explicit justification for IAM write permissions.
- Use IAM Access Analyzer and policy review tooling to identify wildcard permissions, broad trust relationships, and unused access.
- Apply AWS Organizations Service Control Policies where appropriate to prevent privilege-escalation IAM actions outside approved administrative paths.
- Centralise CloudTrail logging and alert on policy changes, role trust changes, user/group membership changes, access-key creation, and unusual role assumption.
- Integrate policy scanning into infrastructure-as-code workflows so risky IAM permissions are identified before deployment.

7.0 Reflection

The task brief's exact reflection questions were not included in the materials supplied for this report request. To avoid inventing assessment questions, this section records concise reflections aligned with the completed phases and should be replaced with the exact Q1-Q5 wording if the task brief provides it.

Reflection 1 - How does least privilege reduce the impact of weak credentials?

Least privilege limits what a compromised identity can do after authentication. In this lab, the highest-risk scenarios were not simply valid accounts; they were identities associated with policy modification, PassRole, or trust-policy changes. Restricting those permissions would reduce the blast radius of credential compromise.

Reflection 2 - What was the most important enumeration lesson?

IAM enumeration quickly exposed the structure of the vulnerable training account and highlighted identities associated with escalation scenarios. This shows why account and permission discovery are valuable to both attackers and defenders: the same visibility that supports attack planning can be used defensively to identify risky identities and review their access.

Reflection 3 - What troubleshooting lesson was learned?

The Phase C instructions assumed a LocalStack endpoint, but the active environment was an AWS-hosted lab and Docker was not installed. Verifying the caller identity and testing IAM enumeration directly against AWS prevented unnecessary troubleshooting of a service that was not part of the actual deployment.

Reflection 4 - Why use automated policy-analysis tools?

Tools such as ScoutSuite and Cloudsplaining can scale review beyond manual inspection and help prioritise dangerous permissions. Their results still need validation against the actual authorization data and environment, so tool output should support rather than replace analyst judgement.

Reflection 5 - What would be prioritised in remediation?

The first priority would be IAM permissions capable of changing authorization or passing privileged roles, because they can create direct escalation paths. Credential controls such as MFA and rotation would be strengthened in parallel, followed by monitoring for high-risk IAM API activity.

8.0 Deliverables Submission Checklist

Phase	Deliverable Description	Filename	Status
Phase A	AI-generated theory summary	phaseA_summary.png	Complete
Phase B	Terraform deployment and AWS CLI connection screenshot	phaseB_setup.png	complete
Phase C	IAM enumeration screenshot	phaseC_enum.png	complete
Phase C	ScoutSuite report summary	phaseC_report.png	complete
Phase D	Risk matrix workbook	phaseD_risk_matrix.xlsx	Complete
Phase D	Cloudsplaining output + risk matrix screenshot	phaseD_matrix.png	complete
Phase E	Cybr/PwnedLabs completion proof	phaseE_labproof.png	Pending
Report	Final internship task report	CSE_AWS_IAM_Report_██████████_Kaur.pdf	Complete

9.0 Additional Observations

Two notable tooling issues were encountered. First, the LocalStack-specific endpoint failed because the lab was connected directly to AWS and Docker/LocalStack was not installed. Second, ScoutSuite installation through pip was blocked by the operating system's PEP 668 externally-managed Python protection; pipx was selected as the safer installation method. These issues reinforce the need to validate environment assumptions and use isolated Python application environments for security tooling.

Declaration & Sign-Off

I confirm that:

- All work in this report is my own except where AI usage is explicitly declared in Section 2.3.
- All technical activities were performed exclusively within the authorised cloud environments listed in Section 1.3.
- No external AWS accounts, production environments, third-party cloud resources, or real customer data were accessed during this task.
- All AWS credentials, access keys, session tokens, and account identifiers used during this task have been redacted in evidence files before submission.
- I have reviewed this report for accuracy, completeness, and professional presentation before submission.

Intern Full Name	Signature	Date of Submission
██████████	██████████	30 Aug 2026